

INTERNATIONAL CYBERSECURITY AND
DIGITAL FORENSICS ACADEMY

Week 1 Practical Laboratory

Information Security Governance in Action

GlobalHealth Connect (GHC) — Executive Governance Simulation

Name	Adeshola Oluwole
Registration Number	C1126CGRCE17211
Course	GRC102 – Information Security Governance
Module	Module 1 – Principles of Information Security Governance
Access Window	05–11 September 2026
Due	11 September 2026, 11:59 PM WAT
Maximum Score	100 marks
Gradebook Contribution	10% – Practical Laboratories

Submission mode: Written report + supporting evidence

Scenario-based lab • No terminal or command-line work is required for this laboratory

Laboratory Overview

You have been appointed Director of Information Security Governance at GlobalHealth Connect (GHC), a mid-sized health-technology organisation that provides cloud-based patient management systems. Following rapid growth, two acquisitions and a contained data-leakage near-miss, the Board has determined that GHC's current ad-hoc security approach is no longer sustainable.

This practical laboratory places you inside a realistic governance environment. Rather than performing technical command-line tasks, you will analyse organisational information, respond to executive requests, design governance artefacts, interpret security metrics and build a practical roadmap that turns a reactive security programme into a business-aligned governance function.

Key Stakeholders

Stakeholder	Role	Primary Concerns
Sarah Chen	Chief Executive Officer	Growth, reputation, operational efficiency and accountability.
Marcus Thorne	Chief Financial Officer	Return on investment, compliance cost and enterprise risk.
Elena Rodriguez	Chief Technology Officer	Developer productivity, technical debt and innovation.
David Miller	Board Member	Accountability, meaningful metrics and regulatory compliance.

Task 1 Governance Blueprint

Executive request: The CEO requires a formal security governance structure with clear roles, reporting relationships and accountability following the recent near-miss.

Current Organisational Context

Employee / Role	Department	Relevant Context
John Smith – IT Manager	IT Operations	Manages infrastructure and performs some security activities.
Jane Doe – Senior Developer	Development	Leads a key product development team.
Mark Johnson – Compliance Officer	Legal & Compliance	Focuses on healthcare regulatory obligations.
Emily White – Data Analyst	Finance	Handles sensitive financial information.
Robert Green – HR Manager	Human Resources	Owns onboarding and offboarding processes.

Required Evidence Task 1

1. A current-state governance gap assessment identifying the most important weaknesses in GHC's ad-hoc model.
2. A proposed security governance organisational chart showing the Board, CEO, governance function and relevant business/technology relationships.
3. A RACI matrix covering at least six governance activities, including policy approval, risk review and incident response planning.

4. A short explanation of how the proposed structure supports accountability, transparency, business alignment and risk management.

Current-State Governance Gap Assessment

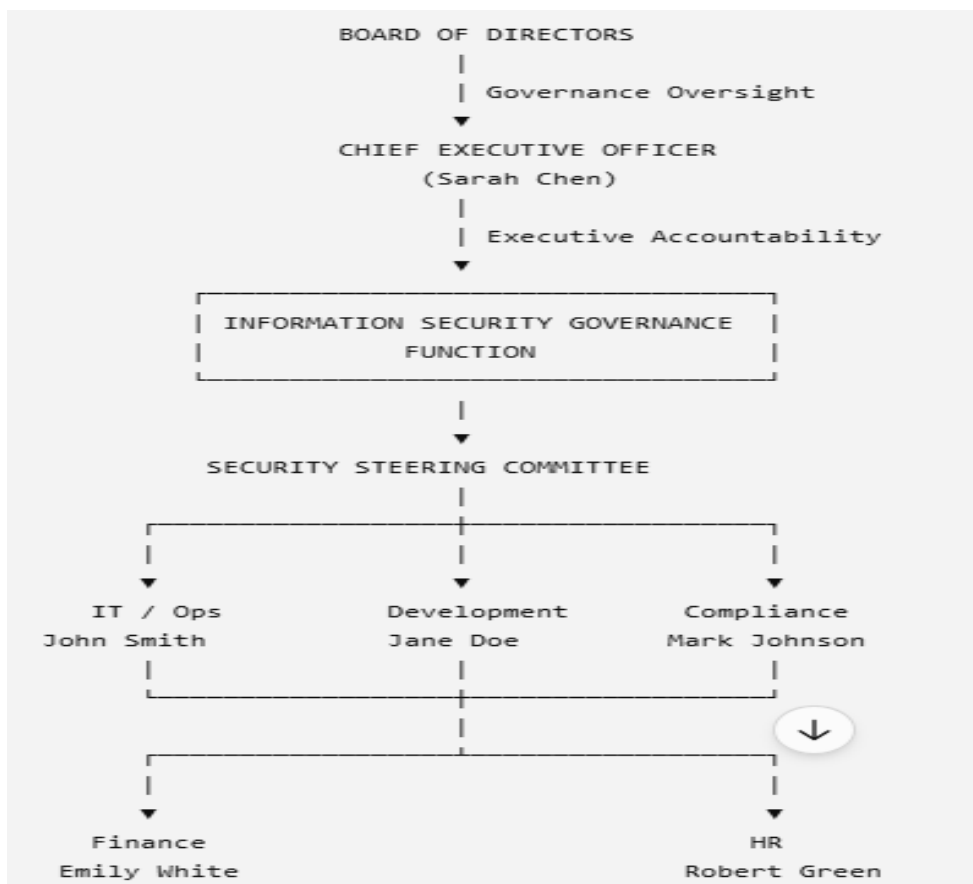
GlobalHealth Connect (GHC) currently has security responsibilities spread across IT, development, compliance, finance and HR. However, the scenario does not identify a dedicated governance function or a clearly defined executive body responsible for coordinating information-security decisions. The IT Manager named John Smith presently manages infrastructure and some security duties, while other stakeholders hold duties that affect security without a clearly documented governance framework.

The governance weakness is not about the lack of security activity by GHC, rather is about no formal coordination, accountability and executive oversight. This is crucial because GHC's business is dependent on patient's information, client trust, regulatory compliance and the growth of the business.

S/No	Governance Aspect	Current situation at GHC	Identified Gap	Business Impact
1	Security accountability	John Smith manages infrastructure and some security activities.	Security accountability appears concentrated within IT rather than being clearly assigned across the organisation.	Security decisions may become overly technical and may not adequately reflect business priorities.
2	Governance oversight	The given scenario does not identify a formal security governance committee or dedicated governance function.	There is no forum for strategic security decisions and oversight.	Vital security issues may not receive quick executive attention.
3	Roles and responsibilities	IT, Development, Compliance, Finance and HR all have security-related responsibilities.	Responsibilities and decision rights are not formally defined.	Potential duplication and gaps during security events.
4	Risk management	Security is primarily associated with IT operations.	No defined organisation-wide security risk ownership is identified.	Business risks may not be consistently assessed alongside technical risks.
5	Policy governance	No formal policy approval structure is described.	Lack of clearly defined policy ownership and approval authority.	Policies may become inconsistent or difficult to enforce.

S/No	Governance Aspect	Current situation at GHC	Identified Gap	Business Impact
6	Incident governance	John Smith manages some security responsibilities, but no formal incident governance structure is identified.	Escalation and executive decision-making responsibilities are unclear.	Delays or confusion could occur during a significant incident.
7	Compliance oversight	Mark Johnson handles healthcare regulatory obligations.	Compliance exists, but its relationship with wider security governance is not clearly structured.	Regulatory requirements may be addressed reactively rather than integrated into security decisions.
8	Business alignment	Security responsibilities are mainly positioned around IT and technical functions.	No formal mechanism is identified for connecting security priorities with	Security investments may be difficult to prioritise based on business value and risk.

Proposed Governance structure



From the above diagram, it has been structured to have a centralised governance structure with cross-functional team participation. This is to ensure that security responsibilities is not attributed to just a department, rather governance function should establish direction, accountability, risk oversight and reporting, while IT, Development, Compliance, Finance and HR continue to own relevant operational responsibilities.

RACI Matrix

This RACI matrix covers up to six governance activities as below:

R – Responsible : The person here performs the activity

A – Accountable: the person here owns the outcome of the activity

C – Consulted: The person here provides the input

I - Informed: the person here is kept aware of the outcome

S/No	Governance Activity	Board	CEO	Governance Function	IT	Development	Compliance	Finance	HR
1	Security policy development	I	A	R	C	C	C	I	C
2	Security policy approval	I	A	R	C	C	C	C	I
3	Enterprise security risk review	I	A	R	C	C	C	C	C
4	Security risk treatment/prioritisation	I	A	R	R	C	C	C	I
5	Incident Response Planning	I	A	R	R	C	C	I	C
6	Security awareness and training	I	A	R	C	C	C	I	R
7	Security metrics and Board Reporting	I	A	R	C	C	C	C	I

Proposed structure

The proposed structure supports 4 core governance principles for GHC:

Accountability: Every security activity must have a owner. The RACI matrix defines who is responsible, accountable, consulted, and informed - e.g. IT implements controls, but the CEO remains accountable for managing risk.

Transparency: Clear reporting lines run from operational teams to the Security Steering Committee, CEO, and Board. This ensures security is escalated using consistent risk metrics and Board-level reporting, not just technical reports.

Business Alignment: Security supports GHC's business goals such as secure systems for market expansion, efficient controls for operations, patient data protection for customer trust, secure AI for innovation, and clear accountability for healthcare/regulatory compliance.

Risk Management: Security shifts from being purely technical to risk-based. Risks are assessed and prioritized by business impact — e.g. a patient data vulnerability gets higher priority than a low-impact technical issue due to potential regulatory, reputational, and operational consequences.

Task 2 - Information Security Charter

The CFO and Board require a formal mandate for the information security programme. Draft a concise but complete Information Security Charter that can be approved by executive management and referenced across the organisation.

GHC Strategic Goals for 2026

Strategic Goal	Business Intent
Expand Market Share	Increase the client base by 25% through new features and entry into two regional markets.
Enhance Operational Efficiency	Reduce overhead by 10% and improve system uptime to 99.99%.
Maintain Customer Trust	Protect patient information and aim for zero major data breaches.
Foster Innovation	Invest in AI-driven diagnostics and secure data-exchange capabilities.
Achieve Regulatory Excellence	Meet applicable healthcare and data-protection obligations proactively.

Charter Sections

- Purpose — why the Information Security Programme exists and how it supports GHC.
- Scope — assets, systems, data, people and third parties covered by the programme.
- Authority — source of authority, decision rights and escalation powers.
- Roles and Responsibilities — high-level governance accountabilities linked to Task 1.
- Key Principles — risk-based, business-aligned, proportionate and continuously improving security.
- Reporting Structure — management, committee and Board reporting expectations.
- Review and Approval — approval authority, review frequency and change control.

Required Evidence Task 2

5. Completed GHC Information Security Charter.
6. A 1–2 paragraph justification memo to Marcus Thorne, CFO, explaining how the Charter supports GHC's strategic goals, accountability and investment decisions.

INFORMATION SECURITY CHARTER

GlobalHealth Connect Information Security Charter

Organisation:	GlobalHealth Connect (GHC)
Document:	Information Security Governance Charter
Version:	1.0
Status:	Proposed for Executive Approval
Owner:	Information Security Governance Function
Approving Authority:	Chief Executive Officer / Board Oversight

1. Purpose

The GHC Information Security Charter sets out who is responsible for protecting information across the business. It gives formal authority for security governance and clarifies how decisions, accountability, and reporting will work to keep GHC's cloud patient-management services secure.

More importantly, it positions security as a business responsibility, not just an IT job. The Charter provides a clear way to manage risks, protect patient and business data, meet regulatory requirements, maintain customer trust, and support GHC's growth and innovation safely.

2. Scope

The Charter covers everyone and everything involved in GHC's operations. This includes all employees, contractors, systems, data, and third parties across every business function and technology environment.

Specifically, it applies to patient and financial data, cloud patient-management systems, IT infrastructure, software development, security policies, incident response, training, compliance, and supplier security. It also includes new areas like AI diagnostics and secure data exchange.

3. Authority

This Charter is approved by GHC leadership and overseen by the Board. The CEO holds overall accountability for security governance and risk escalation. The Information Security Governance Function runs through and monitors the program, while the Security Steering Committee reviews issues and prioritizes work. The Operational teams implement the requirements, and any risks outside tolerance must be escalated to executive leadership.

4. Roles and Responsibilities

At GHC, Information security is owned across the business, not just by IT.

The Board of Directors provides governance oversight and challenges executive leadership on significant risks. Sarah Chen, CEO, holds overall accountability for ensuring security supports business strategy and that major risks are escalated appropriately.

Marcus Thorne, CFO and Elena Rodriguez, CTO support this by assessing financial impacts and making sure security is embedded in technology and product decisions.

The Information Security Governance Function coordinates the program day-to-day — managing policies, risk assessments, metrics, and reporting — while the Security Steering Committee reviews cross-functional issues and sets priorities.

Operational responsibility sits with department leads. John Smith, IT Manager implements technical controls and supports incident response.

Jane Doe, Senior Developer builds security into software development.

Mark Johnson, Compliance Officer monitors regulatory obligations and supports assurance.

Emily White, Data Analyst helps protect sensitive financial data, and Robert Green, HR Manager integrates security into people processes and awareness.

More importantly, all employees and contractors must follow policy, complete training, and report concerns. This structure ensures clear accountability from the Board down to every individual.

5. Key Principles

The way GHC governs security will be guided by 6 core principles.

Risk-based: We prioritize security decisions by what's most likely to happen and what would hurt GHC, our patients, and our business the most. The biggest risks get attention first.

Business-aligned: Security exists to support GHC's goals, not block them. Our investments and controls should enable growth, innovation, and operations — not slow them down

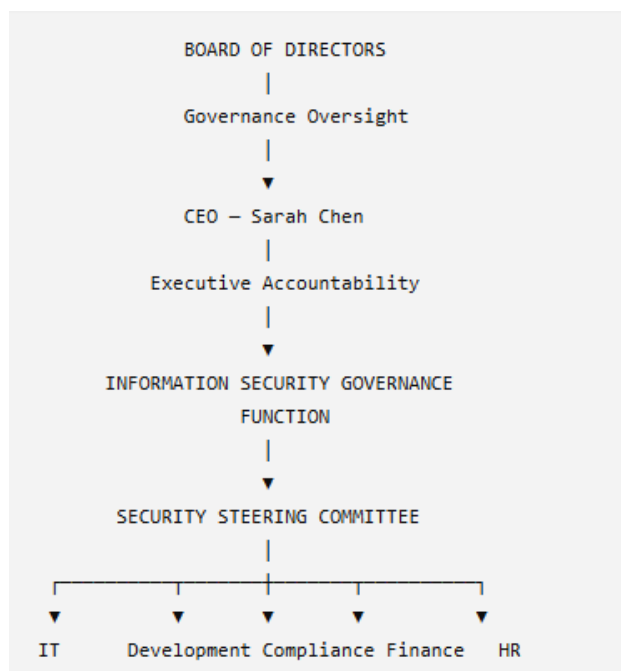
Clear accountability: Everyone needs to know who owns what. Business, tech, and governance teams must understand their role in managing security risk and who makes the final call.

Transparency: Risks, performance, incidents, and key decisions should be reported in plain language to the right people. No jargon, no hiding issues.

Continuous improvement: We'll keep reviewing how we're doing. We'll use metrics, incidents, feedback, and changes in the business to get better over time.

Together, these principles make sure GHC's approach to security is practical, risk-focused, aligned to the business, and always improving — which is exactly what the Charter needs to deliver.

6. Reporting Structure



7. Review and Approval

This Charter will be reviewed at least once a year. We'll also review it whenever there's a major change to GHC's strategy, technology, regulations, structure, or risk profile. The Information Security Governance Function is responsible for coordinating the review and recommending any updates. Any material changes go to the relevant executive for approval, and major governance changes will be overseen by the Board. The Charter should also be reviewed after a major security incident or significant organizational change to make sure our governance is still working as intended.

Justification Memo to the CFO

To: Marcus Thorne, CFO

From: Information Security Governance Function

Date: 12 September 2026

Subject: Approval Request – Information Security Governance Charter

I am writing to recommend that we formally adopt the Information Security Governance Charter. The bottom line is this: security **cannot** sit with IT alone anymore. As GHC grows, we need a company-wide approach that ties security directly to how we run the business. This Charter gives us that structure. It supports our 2026 goals in a very practical way. As we move into new regions and take on more clients, we have to prove we can protect patient and business data. The Charter makes it clear who's accountable for that. It also makes sure we think about security upfront when we build new products, roll out AI diagnostics, or set up data exchanges with partners. And it gives us a consistent way to handle regulatory requirements so we don't lose the trust healthcare customers expect from us.

From a financial and risk standpoint, the Charter helps us make better decisions with money. Currently, security spending can look like just another IT cost. This framework lets us prioritize based on real business risk and impact. With defined roles and clear reporting, you and the exec team will see where we need to invest, what risks we're living with, and whether our controls are working. That means fewer surprises, less wasted spend on last-minute compliance fixes, and stronger accountability for how we use security resources across GHC. In short, it helps us grow safely, stay compliant, and protect our reputation. Happy to walk you through it if you would like to discuss before we take it to the Board.

Best regards,

Task 3 Board Reporting and Security Metrics

The Board has requested a concise, business-focused security update. Select the most decision-useful metrics from the six-month dataset, interpret the trends and present the organisation's security posture without unnecessary technical jargon.

Month	Phishing	Malware	Critical Vulns Patched	Patching %	Training %	High-Risk Incidents
September	150	25	10 of 15	67%	45%	2
October	180	30	12 of 20	60%	50%	3
November	210	35	15 of 25	60%	55%	4
December	250	40	18 of 30	60%	60%	5
January	280	45	20 of 35	57%	65%	6
February	320	50	22 of 40	55%	70%	7

Required Evidence Task 3

7. A one-page Board Executive Summary containing an overall Red/Amber/Green posture assessment and justification.
8. Five selected security metrics showing current status, six-month trend and concise business commentary.
9. At least two priority risks/issues and two actionable recommendations.
10. A short rationale explaining why your five selected metrics are suitable for Board oversight.

Board Executive Summary

I would recommend an overall RED rating as the overall posture: ● RED — Deteriorating

The strongest reason is that several indicators are moving in the wrong direction at the same time.

Taking a look at from September to February, we can deduce that:

- Phishing attempts increased from 150 to 320 — approximately 113% increase.
- Malware incidents increased from 25 to 50 — 100% increase.
- High-risk incidents increased from 2 to 7 — 250% increase.
- Patching performance declined from 67% to 55%.
- Critical vulnerabilities increased from 15 to 40.
- Training completion improved from 45% to 70%, which is positive, but this improvement has not yet translated into a reduction in the other risk indicators.

The combination suggests that GHC's risk exposure is increasing faster than its ability to reduce or contain that exposure. The training result is encouraging, but then it should not by itself justify an Amber or Green rating because the wider risk picture remains negative.

Five Board Level Security Metrics

I recommend the below five metrics as they will give a balance between risk, threat activity and control effectiveness.

1. High-risk security incidents
2. Critical vulnerability exposure/patching
3. Phishing attempts
4. Malware incidents
5. Security training completion

Metric	September	February	Trend
High-risk security incidents	2	7	Increasing
Critical vulnerability exposure/patching	15	40	Increasing
Critical vulnerabilities patched	10	22	Increasing but insufficient
Patching rate	67%	55%	Declining
Phishing attempts	150	320	Increasing
Malware Incidents	25	50	Increasing
Security training completion	45%	70%	Improving

Why these 5 metrics were selected

These metrics were selected because they give the Board a fuller picture of security than just counting incidents. All these put together cover threats, technical gaps, real high-risk events, and the human side, so we do not just have technical numbers been reported only.

High-risk incidents – shows how serious the events are that need executive attention

Critical vulnerabilities & patching – shows where our tech is weak and how fast we fix it

Phishing attempts – shows external pressure and social-engineering risk to staff.

Malware incidents – shows exposure to malicious software and potential operational impact

Security-training completion – shows how well employees understand their role in security

Task 4 Security Steering Committee

A dispute has emerged between the CTO and IT Manager regarding a proposed password policy. The CTO believes the policy will create excessive friction; the IT Manager argues that stronger controls are necessary. The CEO wants a formal Security Steering Committee (SSC) to resolve such cross-functional issues.

Conflict context: The proposed policy requires 16-character complex passwords changed every 30 days without password-manager integration. The CTO recommends a more balanced approach emphasising multi-factor authentication and secure password-management.

Required Evidence Task 4

11. Security Steering Committee Terms of Reference covering purpose, scope, membership, responsibilities, meeting cadence, decision authority and reporting.
12. A sample agenda for the first SSC meeting with the password-policy conflict as a key discussion item.
13. A 1–2 paragraph briefing note to the CEO explaining how the SSC will resolve cross-functional conflict and maintain strategic alignment.

Security Steering Committee – Terms of Reference (ToR)

GlobalHealth Connect (GHC)
Security Steering Committee — Terms of Reference
Document Status: Proposed
Version: 1.0
Effective Date: Upon approval
Committee Owner: Chief Executive Officer
Reporting To: CEO / Board Oversight

1. Purpose

The Security Steering Committee (SSC) provides cross-functional direction and oversight for information security at GHC. It creates a forum to align security with business goals, ensure decisions are risk-based, and resolve conflicts between departments.

2. Scope

The SSC covers organization-wide security governance that needs executive or cross-functional decisions. It focuses on strategy, policy, risks, investments, incidents, compliance, and new products — but does not take over the day-to-day work of IT, Compliance, HR, or Finance.

3. Membership

The SSC is made up of senior leaders from business, tech, compliance, finance, HR, and development to ensure all perspectives are represented. The Information Security Governance Function coordinates meetings and reporting, and specialists can be invited as needed.

4. Responsibilities

The SSC sets security strategy, oversees major risks, reviews policies, and prioritizes security investments. It also monitors performance, resolves cross-functional issues, oversees major incidents and compliance, and drives continuous improvement of GHC's security governance.

5. Meeting Cadence

The SSC will meet monthly at a minimum. Extra meetings can be called for major incidents, urgent risks, policy conflicts, big initiatives, or time-sensitive investment decisions, with materials sent out in advance.

6. Decision Authority

The SSC can review, prioritize, and recommend on security initiatives, policies, investments, risks, and issues, and escalate anything beyond its authority to the CEO or Board. It provides governance and decision support, but final accountability still sits with executive and Board leadership.

7. Reporting

The SSC will report regularly to the CEO and Board on key risks, incidents, vulnerabilities, performance, compliance, investments, and decisions needed. Reports will focus on business impact and risk, not just technical details.

8. Meeting Records and Actions

The Committee Coordinator will keep records of agendas, attendance, decisions, actions, owners, deadlines, and escalations. All action items will be tracked and reviewed at each meeting until they're closed.

9. Review of Terms of Reference

These Terms of Reference will be reviewed at least annually, or sooner if there's a major change to GHC's structure, strategy, technology, or risk profile. Any material changes must be approved through the proper governance process.

CEO Briefing Note**To:** Sarah Chen, Chief Executive Officer**From:** Information Security Governance Function**Subject:** Establishment of the Security Steering Committee

The Security Steering Committee will give GHC a formal, cross-functional way to direct and oversee information security. By bringing together tech, IT, development, compliance, finance, HR, and executive leadership, the SSC ensures security decisions balance both risk and business needs. This is critical when security goals clash with operations or innovation — like the current disagreement between the CTO and IT Manager over the proposed password policy.

The SSC will also make accountability clearer through defined decision-making, escalation, and reporting. Instead of departments handling big security issues in isolation, the Committee will provide a structured forum to assess risk, impact, resources, and whether controls actually work. The password-policy dispute should be the SSC's first case — using it to reach a proportionate, risk-based decision that still supports GHC's wider strategic objectives.